

OS command injection, simple case

Topic: Command Injection | Difficulty: Apprentice

Description

The product stock check feature constructs and executes an OS-level shell command using the user-supplied 'storeId' parameter without sanitization. An attacker can append shell operators to inject arbitrary commands which execute with the privileges of the web server process.

Steps to Exploit

1. Navigate to a product page and click 'Check stock'.
2. Intercept the POST request to /product/stock in Burp Suite.
3. Locate the 'storeId' parameter in the request body.
4. Modify the 'storeId' value to: 1|whoami
5. Forward the modified request.
6. Observe the response contains the output of the 'whoami' command.

Proof of Concept

Payload:

```
1|whoami
```

Injected Command:

```
stockreport.pl 1|whoami
```

Response Output:

```
peter-xxxxxx (web server process username printed in response)
```

Impact

- Arbitrary OS command execution on the server.
- Full compromise of the web server and hosted data.
- Potential for lateral movement within the internal network.
- Exfiltration of sensitive files including credentials.
- Complete loss of confidentiality, integrity, and availability.

Mitigation / Remediation

1. Avoid passing user-controlled data to OS-level shell functions.
2. If shell execution is required use an allowlist for permitted parameter values.
3. Run the web server process under a least-privilege account.
4. Implement a WAF to detect and block shell metacharacters in input.

CVSS Score

CVSS v3.1: 9.8 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

- Attack Vector: Network - exploitable via a standard HTTP POST request.
- Attack Complexity: Low - single parameter modification required.
- Privileges Required: None - no authentication required.
- User Interaction: None.
- Confidentiality / Integrity / Availability: High - full server RCE achieved.